

Whatsapp

1. Descripción del mecanismo criptográfico de WhatsApp

WhatsApp implementa cifrado de extremo a extremo utilizando el **Signal Protocol**. El objetivo del diseño es garantizar que únicamente los dispositivos del emisor y del receptor puedan acceder al contenido de los mensajes, incluso si los servidores de WhatsApp fueran comprometidos¹.

1. Modelo multi-dispositivo

Cada usuario puede tener múltiples dispositivos (principal y acompañantes). Cada dispositivo mantiene su propio conjunto independiente de claves criptográficas. Esto implica que:

- Comprometer un dispositivo no permite descifrar mensajes enviados a otros dispositivos del mismo usuario.
- Las sesiones cifradas se establecen por dispositivo, no por cuenta.

Este diseño reduce el impacto de compromisos parciales.

2. Tipos de claves públicas

Cada dispositivo genera tres tipos de claves Curve25519:

- **Identity Key Pair**: clave de largo plazo que identifica criptográficamente al dispositivo.
- **Signed Pre Key**: clave de mediano plazo firmada por la Identity Key (permite verificar que esa clave realmente fue generada por ese dispositivo, no fue sustituida por un atacante, está criptográficamente vinculada a la identidad permanente del dispositivo; en otras palabras: la Identity Key actúa como raíz de confianza del dispositivo). Permite autenticación sin interacción inmediata.
- **One-Time Pre Keys**: claves de un solo uso que proporcionan secreto perfecto hacia adelante en el primer mensaje. Si una clave actual es comprometida, los mensajes antiguos siguen siendo seguros. Es decir: cada mensaje usa claves derivadas que evolucionan, las claves pasadas no pueden reconstruirse desde las actuales, comprometer el estado presente no permite descifrar el pasado. Se logra usando: claves efímeras, ratcheting criptográfico.

Estas claves permiten que un usuario inicie una sesión segura incluso si el receptor está desconectado.

¹WhatsApp Encryption Overview, 2024.

3. Establecimiento inicial de sesión (X3DH)

Cuando un usuario A (en uno de sus dispositivos) inicia comunicación con un dispositivo B (del usuario receptor), se realiza una combinación de varios acuerdos ECDH independientes:

$$\text{master_secret} = \text{ECDH}(I_A, S_B) \parallel \text{ECDH}(E_A, I_B) \parallel \text{ECDH}(E_A, S_B) \parallel \text{ECDH}(E_A, O_B)$$

I = Identity Key (clave permanente)

S = Signed Pre Key (clave semi-permanente)

E = Ephemeral Key (clave efímera generada para la sesión)

O = One-Time Pre Key (clave de un solo uso)

Cada término aporta una propiedad distinta:

- Autenticación del receptor.
- Secreto efímero: se genera para una sesión específica, no se reutiliza, se destruye después. Aporta: protección ante compromisos futuros, mayor entropía en cada sesión.
- Protección frente a ataques de repetición. El atacante intercepta un mensaje y lo retransmite más tarde, sin necesidad de descifrarlo; el objetivo puede ser: repetir una acción (por ej una orden, forzar un estado inconsistente, engañar al sistema)
- Forward secrecy inicial.

A partir de este secreto se derivan mediante HKDF:

- **Root Key**: estado central del protocolo. Se actualiza cada vez que ocurre un nuevo DH ratchet. Sirve para derivar nuevas Chain Keys.
- **Chain Keys**: clave que evoluciona con cada mensaje (hash ratchet). De ella se derivan las Message Keys.

4. Double Ratchet

Después del establecimiento inicial, cada mensaje hace evolucionar el estado criptográfico mediante dos mecanismos complementarios:

a) Hash Ratchet

Para cada mensaje:

$$\text{MessageKey} = \text{HMAC}(\text{ChainKey}, 0x01)$$

$$\text{ChainKey} = \text{HMAC}(\text{ChainKey}, 0x02)$$

HMAC significa: Hash-based Message Authentication Code

Es un mecanismo que combina: una función hash criptográfica (por ejemplo SHA-256), con una

clave secreta. Sirve para: garantizar integridad (el mensaje no fue modificado), garantizar autenticidad (solo quien conoce la clave pudo generarlo). Formalmente: $\text{HMAC}(K, m)$ donde: K es la clave secreta, m es el mensaje. En el Double Ratchet se usa HMAC para derivar nuevas claves de forma segura.

Esto significa que cada mensaje usa una clave distinta y que las claves anteriores no pueden recuperarse si se compromete el estado actual.

b) DH Ratchet (Diffie–Hellman Ratchet)

En cada intercambio de respuesta se genera una nueva clave efímera Curve25519 y se realiza un nuevo ECDH. El resultado actualiza la Root Key:

$$\text{ChainKey}, \text{RootKey} = \text{HKDF}(\text{RootKey}, \text{ECDH_output})$$

Este mecanismo proporciona:

- **Forward secrecy:** mensajes antiguos no pueden descifrarse si se compromete una clave futura.
- **Post-compromise security:** el sistema se recupera después de una intrusión.

5. Derivación y uso de Message Keys

Cada Message Key tiene 80 bytes que se dividen en:

- 32 bytes para AES-256.
- 32 bytes para HMAC-SHA256.
- 16 bytes para IV(Initialization Vector). Sirve para: evitar que dos mensajes iguales produzcan el mismo cifrado, garantizar aleatoriedad en el cifrado. No es secreto, pero debe ser impredecible.

El mensaje se cifra con AES-256-CBC y se autentica con HMAC-SHA256. Al mensaje cifrado se lo llama cyphertext. El servidor solo retransmite el ciphertext (modelo *client-fanout*).

6. Mensajes en grupos

Para mejorar eficiencia en grupos grandes se usa un mecanismo denominado **Sender Key**:

- Se genera una Chain Key compartida para el grupo.
- Cada mensaje del grupo deriva su propia Message Key.
- El mensaje se firma con una clave de firma independiente.

Si un miembro abandona el grupo, las claves se regeneran para evitar que pueda descifrar mensajes futuros.

7. Seguridad de transporte

Además del cifrado extremo a extremo, la conexión cliente-servidor está protegida con el protocolo Noise (Curve25519, AES-GCM, SHA-256). Esto protege metadatos frente a observadores de red, pero no sustituye el cifrado extremo a extremo. El protocolo Noise encapsula el cifrado extremo a extremo, hay dos capas:

1. Cifrado extremo a extremo (Signal Protocol): protege el contenido frente al servidor.
2. Cifrado de transporte (Noise Protocol): protege la conexión cliente-servidor frente a atacantes de red.

8. Propiedades criptográficas globales

El sistema completo ofrece:

- Confidencialidad extremo a extremo.
- Integridad y autenticación de mensajes.
- Forward secrecy.
- Post-compromise security.
- Separación criptográfica por dispositivo.
- Verificación manual contra ataques Man-in-the-Middle.

Este diseño combina acuerdos ECDH, funciones hash, derivación de claves (HKDF) y cifrado simétrico autenticado para construir un sistema resistente frente a compromisos parciales y ataques retrospectivos.

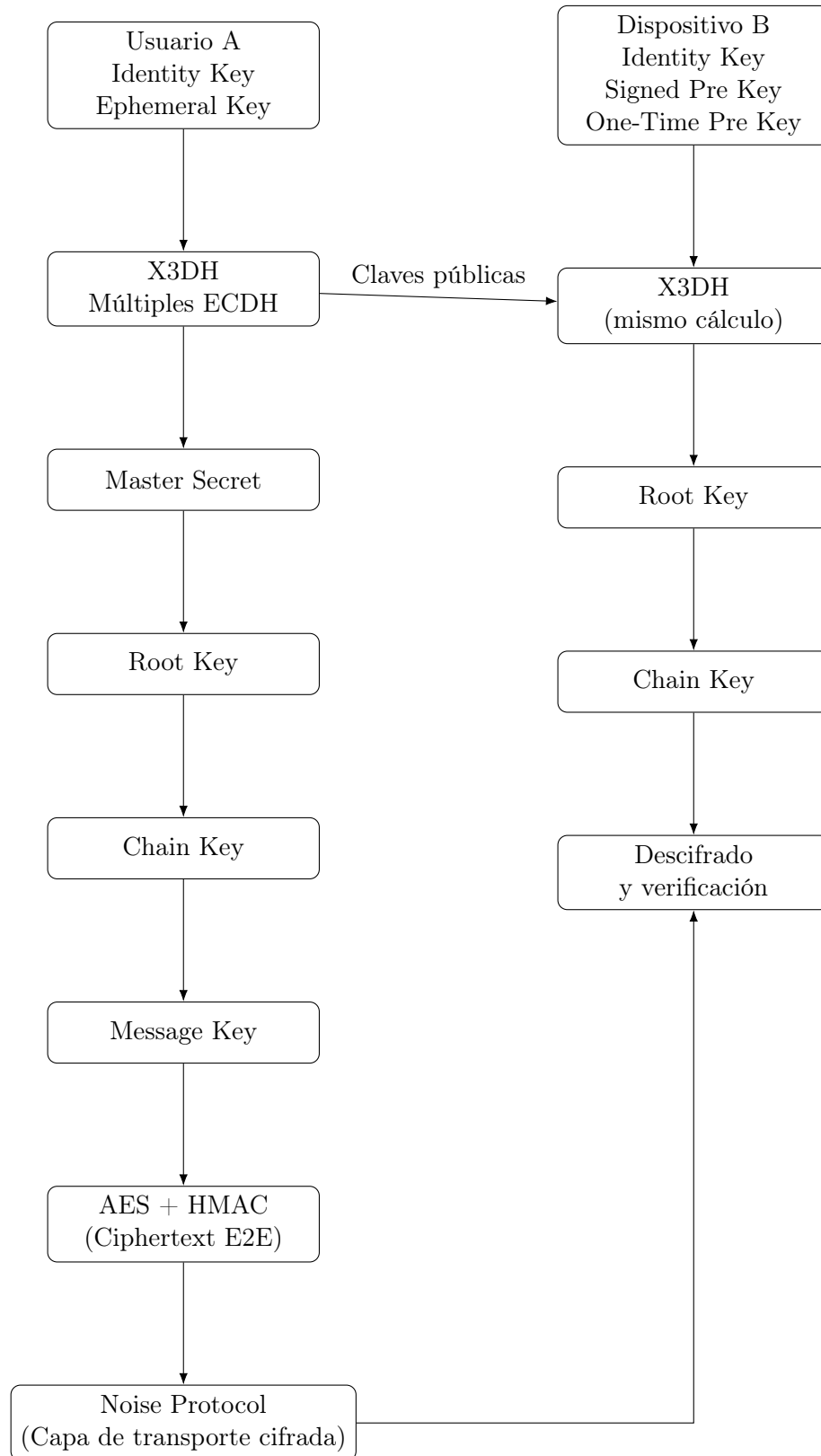


Figura 1: Esquema global simplificado del cifrado extremo a extremo de WhatsApp